Comprendre le blocage par e-mail

Lecture du code de connexion de School Kadija

> **A clarifier : le code ne bloque pas un compte apres plusieurs echecs et n'envoie aucun e-mail. Il reserve la connexion a une adresse e-mail precise.**

Ce que le code fait

La page connexion.php affiche un formulaire e-mail / mot de passe. A l'envoi, le serveur verifie le format de l'adresse, la configuration du mot de passe, puis compare l'adresse saisie a celle de l'administrateur. Si les deux identifiants sont valides, une session authentifiee est ouverte et l'utilisateur est redirige vers deux.php.

Les deux fichiers concernes

- auth.php : adresse administrateur, demarrage et securisation de session, verification de l'etat connecte, protection des pages et deconnexion.
- connexion.php : reception du formulaire, validation des identifiants, affichage des erreurs et redirection apres connexion.

Parcours d'une tentative

1. L'utilisateur saisit son e-mail et son mot de passe sur connexion.php.
2. Le navigateur envoie les champs en POST au meme fichier.
3. PHP controle les valeurs, puis compare e-mail et mot de passe.
4. Echec : un message generique est affiche. Reussite : la session est renouvelee et ouverte.

1. Le fichier auth.php

Les fonctions partagees par les pages protegees

Adresse autorisee (lignes 6-9)

```
school_admin_email() retourne fayebayedame399@gmail.com.
```

Cette fonction renvoie l'unique adresse autorisee. C'est une liste blanche a un seul membre : toute autre adresse sera refusee, meme si le mot de passe est correct.

Demarrage de session (lignes 11-22)

- session_status() evite de demarrer une session deja active.
- session.use_strict_mode reduit le risque d'accepter un identifiant de session fourni par un visiteur.
- __DIR__ pointe vers le dossier du projet. Le code cree sessions/ si necessaire, avec les permissions 0700.
- Si le dossier est accessible en ecriture, PHP y stocke les sessions, puis session_start() reprend ou cree la session.

Configuration des identifiants (lignes 24-28)

```
school_credentials_configured() exige une adresse admin valide ET SCHOOL_ADMIN_PASSWORD_HASH non vide.
```

Le mot de passe en clair n'est pas stocke dans le code : le serveur doit fournir son empreinte dans la variable d'environnement SCHOOL_ADMIN_PASSWORD_HASH.

Etat connecte et protection (lignes 30-41)

school_is_authenticated() retourne vrai uniquement si la session contient school_authenticated avec la valeur booleenne true. school_require_authentication() redirige sinon vers connexion.php et stoppe le script. Chaque page privee doit appeler cette fonction.

Deconnexion (lignes 43-51)

school_logout() vide les donnees de session, expire le cookie de session si les cookies sont actifs, puis detruit la session cote serveur. connexion.php redirige ensuite vers la page de connexion.

2. Le fichier connexion.php

Traitement du formulaire et decision d’acces

Preparation de la page (lignes 2-16)

require_once charge auth.php une seule fois. $message commence vide. Si l’URL contient ?page=deconnexion, le code deconnecte puis redirige. Si une session valide existe deja, l’utilisateur est envoye vers deux.php.

Lecture des champs (lignes 18-20)

```
Les deux valeurs sont lues depuis POST; trim() retire les espaces de l’adresse.
```

Le traitement n’a lieu que pour une requete POST. ?? fournit une chaine vide si le champ manque. Le mot de passe conserve sa valeur exacte.

Les controles, dans l’ordre (lignes 22-28)

1. filter_var valide la syntaxe de l’adresse et le mot de passe ne doit pas etre vide.
2. school_credentials_configured() exige une adresse admin valide et un hash configure.
3. hash_equals compare les adresses en minuscules, sans comparaison prematurement arretee.
4. password_verify compare le mot de passe saisi au hash de l’environnement.

Le OU (||) signifie que l’echec de l’un des deux controles suffit a refuser l’acces. L’adresse et le mot de passe incorrects donnent le meme message, ce qui evite de reveler quel champ etait juste.

Connexion reussie (lignes 29-34)

```
session_regenerate_id(true);  // nouvel identifiant de session
```

```
La session marque school_authenticated a true.
```

```
Redirection vers deux.php puis fin du traitement.
```

Le nouvel identifiant aide a prevenir la fixation de session. Le marqueur indique que l’utilisateur est authentifie. La redirection termine le traitement avant le rendu HTML.

3. Formulaire, limites et synthese

Le reste de connexion.php, lignes 38-119

Partie HTML

- <form action="connexion.php" method="post"> envoie les donnees au serveur avec POST.
- type="email" aide le navigateur a controler le format; required empeche un envoi vide depuis l'interface. PHP doit refaire ces controles car une requete peut etre fabriquee.
- name="email" et name="motdepasse" sont les noms transmis dans $_POST. autocomplete aide le navigateur a proposer les champs connus.
- htmlspecialchars($message) echappe le message avant insertion dans la page, pour eviter qu'un texte soit interprete comme HTML.
- Le pied de page affiche l'annee courante. Le CSS gere l'apparence; il ne decide pas qui peut entrer.

Que signifie "blocage par e-mail" ici ?

C'est une restriction d'identite : une seule adresse est admise. Le message d'erreur n'est pas un blocage temporaire. Chaque nouvel essai est traite de nouveau. Aucun compteur d'essais, minuterie, blocage d'adresse IP, courriel d'alerte ou lien de reinitialisation n'apparait dans ces fichiers.

Configuration requise

- Definir SCHOOL_ADMIN_PASSWORD_HASH sur le serveur avec un hash genere par password_hash().
- Rendre cette variable accessible au processus PHP; sans elle, la page signale que la connexion n'est pas configuree.
- Verifier que les pages privees appellent school_require_authentication().

> **Resume : e-mail autorise + mot de passe valide -> session authentifiee -> acces a deux.php. Toute autre combinaison est refusee, mais le compte n'est pas verrouille apres plusieurs echecs.**

Code analyse : auth.php (lignes 1-51) et connexion.php (lignes 1-119). Etat constate au 29 octobre 2026.